step: 1.2

plan: ../PLAN-MASTER.md

agent: senior-developer

status: done

completed_at: 2026-11-02T21:15:00+07:00

deps: [1.1]

STEP 1.2 — Chống XSS `DOMPurify`, Cookie `httpOnly` (LAN/HTTPS) & Mã hóa Secrets AES-256-GCM (`G0-2` & `G0-3`)

Input nhận

- Handoff Payload từ `STEP-1.1` (Auth/RBAC đã được dựng vững chắc).

Nhiệm vụ

1. Cài đặt / tích hợp `isomorphic-dompurify` làm Seam trung tâm tại `src/lib/sanitize.ts`.
2. Áp dụng `sanitizeHtml` cho `src/components/ui/rich-markdown.tsx` và `src/components/ui/wysiwyg-editor.tsx`, cấu hình cho phép các thẻ an toàn (b, i, u, s, span, font, mark, p, h1-h3, ul, ol, li, blockquote, pre, code, a, table) và attributes (style, color, href, target), triệt tiêu hoàn toàn `<script>`, `<svg onload>`, `<img onerror>`, `javascript:`.
3. Escape HTML trong `src/lib/mail.ts` và kích hoạt `rejectUnauthorized: true` mặc định cho kết nối SMTP TLS.
4. Cấu hình cookie phiên `flowboard_session` trong `src/lib/auth.ts`: bắt buộc `httpOnly: true`, `sameSite: "lax"`, `secure: process.env.COOKIE_SECURE === "true"` (đảm bảo chạy cả HTTP LAN lẫn HTTPS). Đồng bộ client fetch credentials `same-origin` trong `src/lib/tab-cache.ts` và `src/app/board/board-view.tsx`.
5. Tạo `src/lib/crypto-secrets.ts` sử dụng thuật toán `AES-256-GCM` để mã hóa/giải mã các trường bí mật.
6. Cập nhật `src/lib/system-config.ts` và `src/app/api/system/config/route.ts`:
   - 8 trường nhạy cảm (`smtpPass`, `zaloSecretKey`, `zaloRefreshToken`, `discordWebhookUrl`, v.v.) khi lưu vào DB `SystemSetting` hoặc file backup JSON đều được mã hóa dưới dạng `enc:v1:...`.
   - `GET /api/system/config` luôn trả về chuỗi mặt nạ `******` cho các trường có giá trị.
   - Hàm `POST /api/system/config` xóa bỏ `console.log(body)` và kiểm tra SSRF trên `discordWebhookUrl` (chỉ cho phép domain discord.com).
7. Xóa `cookies.txt` khỏi Git và bổ sung vào `.gitignore`.

Definition of Done

- [x] XSS payloads `<script>`, `<svg onload>`, `<img onerror>` bị lọc sạch 100% trong cả Markdown preview lẫn WYSIWYG editor.
- [x] Cookie `flowboard_session` mang cờ `HttpOnly; SameSite=Lax`. Đăng nhập hoạt động mượt mà cả LAN HTTP và HTTPS.
- [x] `GET /api/system/config` không lộ plaintext passwords/secrets. Secret trong DB được mã hóa AES-256-GCM.
- [x] Không còn `console.log` secret ra container stdout.
- [x] `cookies.txt` không còn tồn tại trong repo và đã có trong `.gitignore`.

Đã làm

- Cài đặt `isomorphic-dompurify` và tạo seam trung tâm `src/lib/sanitize.ts` với whitelist thẻ và thuộc tính rich-text an toàn của KZTEK, cấm tuyệt đối script, svg, math, iframe, form, on* handlers và URL javascript:.
- Tích hợp `sanitizeHtml` vào `src/components/ui/rich-markdown.tsx` thay thế regex cũ; áp dụng vào `src/components/ui/wysiwyg-editor.tsx` khi nhận value ngoại vi, khi paste dữ liệu từ clipboard và trước khi phát sự kiện onChange.
- Bổ sung helper `escapeHtml` và áp dụng cho toàn bộ template email (`generateTaskAssignedEmailHtml`, `generateStatusChangedEmailHtml`, `generateTaskCommentEmailHtml`, `generateTaskMentionEmailHtml`, `generateTestEmailHtml`).
- Cấu hình SMTP TLS mặc định kích hoạt xác thực chứng chỉ: `rejectUnauthorized: process.env.SMTP_REJECT_UNAUTHORIZED !== "false"`.
- Cấu hình cookie phiên `flowboard_session` trong `src/lib/auth.ts`: `httpOnly: true`, `sameSite: "lax"`, `secure: process.env.COOKIE_SECURE === "true"`, `path: "/"`.
- Bổ sung `credentials: "same-origin"` vào các lời gọi fetch trong `src/app/board/board-view.tsx` và đồng bộ với `src/lib/tab-cache.ts`.
- Xây dựng module mã hóa `src/lib/crypto-secrets.ts` bằng thuật toán AES-256-GCM chuẩn định dạng `enc:v1:<iv>:<tag>:<ciphertext>`, hỗ trợ tương thích ngược cho dữ liệu plaintext cũ và mặt nạ `******`.
- Cập nhật `src/lib/system-config.ts` mã hóa các secret (`smtpPass`, `zaloAppSecret`, `zaloOaSecretKey`, `zaloAccessToken`, `zaloRefreshToken`, `discordClientSecret`, `discordBotToken`, `discordWebhookUrl`) khi ghi vào DB `SystemSetting` và file backup disk; tự động giải mã khi đọc vào memory cho runtime; trả mặt nạ `******` qua `getMaskedSystemConfigAsync()`.
- Chống SSRF cho `discordWebhookUrl` tại schema validation và persistence (chỉ cho phép `https://discord.com/api/webhooks/` hoặc `https://discordapp.com/api/webhooks/`).
- Xóa bỏ `console.log(body)` trong `POST /api/system/config` để triệt tiêu nguy cơ lộ secrets trên container logs.
- Xóa file `cookies.txt` và thêm vào `.gitignore`.
- Viết bộ kiểm thử tự động `scripts/test_step_1_2.ts` xác thực 22/22 kịch bản pass 100%.

Artifact

- `src/lib/sanitize.ts`: Seam trung tâm lọc HTML chống XSS bằng DOMPurify.
- `src/lib/crypto-secrets.ts`: Module mã hóa/giải mã AES-256-GCM.
- `scripts/test_step_1_2.ts`: Script kiểm thử tự động toàn diện cho Bước 1.2.
- `src/components/ui/rich-markdown.tsx`, `src/components/ui/wysiwyg-editor.tsx` (tích hợp sanitize).
- `src/lib/mail.ts` (escapeHtml & TLS rejectUnauthorized).
- `src/lib/auth.ts` (cookie httpOnly: true).
- `src/lib/system-config.ts` & `src/app/api/system/config/route.ts` (AES-256-GCM encryption, masking, SSRF check).
- `.gitignore` (chặn cookies.txt).

Quyết định quan trọng

- Khóa AES-256-GCM được sinh bằng scryptSync (32 bytes) từ `AUTH_SECRET` kết hợp salt hệ thống `"kztek-system-salt"` (hoặc biến `ENCRYPTION_KEY` nếu được cấu hình riêng).
- Giữ cơ chế tương thích ngược thông minh: `decryptSecret` kiểm tra tiền tố `enc:v1:`, nếu là dữ liệu plaintext cũ thì giữ nguyên để hệ thống không bị crash khi nâng cấp DB giữa chừng.
- Giữ logic `secure: process.env.COOKIE_SECURE === "true"` kết hợp `httpOnly: true` để hỗ trợ cả mô hình mạng LAN nội bộ chạy HTTP lẫn triển khai Cloud qua HTTPS mà không mất session.

Handoff Payload — bước sau đọc phần này (chỉ phần này, không cần đọc "Đã làm")

- do_not_redo:
  - Không cần sửa đổi lại `sanitizeHtml`, `crypto-secrets.ts`, cơ chế mã hóa `enc:v1:...` của `SystemSetting` và cookie `httpOnly: true`.
  - Không xóa `cookies.txt` khỏi `.gitignore`.
- watch_out:
  - Khi viết code UI mới liên quan đến nội dung rich-text hoặc HTML preview, luôn đi qua Seam `sanitizeHtml` (`@/lib/sanitize`) thay vì tự lọc regex.
  - Các API router trả cấu hình hệ thống ra client luôn gọi `getMaskedSystemConfigAsync()` để đảm bảo password không bao giờ bị trả về dạng plaintext.
- next_inputs:
  - Bước 1.3: Cố định ID/Key Dự án Kép (`G0-4` & `G0-6`) và chuẩn hóa luồng Activity Log / SSE Event.

Commit

- Hash: (cập nhật sau khi commit)
- Đã push: false

Status icons: ⬜ Todo | 🔄 In Progress | ✅ Done | 🔴 Blocked | ⏭️ Skipped